

4.8 - MFA, SSO e autenticação entre serviços

Identidade humana e identidade de máquina

Credential stuffing no painel admin

- **Painel admin acessado só com usuário e senha**
 - Credenciais vazadas de outro serviço reaproveitadas

LUNALOG

O painel administrativo da LunaLog, onde transportadoras configuram integrações e visualizam dados financeiros, era acessado apenas com usuário e senha. Numa única noite, um ataque de credential stuffing usando credenciais vazadas de outro serviço comprometeu três contas de administrador. O atacante exportou dados de 1.200 entregas antes de ser detectado pela equipe. Roberto descobriu que as senhas reutilizadas pelos próprios admins foram a porta de entrada. A partir desse incidente, MFA obrigatório para acessos privilegiados deixou de ser opcional de onboarding e virou item de arquitetura de segurança.

MFA: mais de um fator de identidade

Algo que você sabe, tem e é

- **Fator de conhecimento é algo que você sabe**
 - Senha e PIN são o fator mais fraco isolado
- **Fator de posse é algo que você tem**
 - TOTP, push e chave de hardware reforçam o login
- **Fator de inerência é algo que você é**
 - Biometria valida sem exigir memória do usuário
- **FIDO2 e passkeys resistem a phishing por design**

SSO: conveniência com responsabilidade

O que SSO entrega

- Um login para múltiplos sistemas
- Menos senhas, menos reuso inseguro
- Onboarding e offboarding centralizados
- Experiência de uso mais fluida

O que SSO concentra de risco

- Comprometer o IdP compromete tudo
- Disponibilidade do IdP vira ponto crítico
- Exige MFA forte no provedor de identidade
- Falha de sessão se propaga entre sistemas

Serviços também precisam de identidade

- **Serviço a serviço não pode usar credencial humana**
 - Senha de pessoa em script é segredo que vaza
- **Client credentials flow autentica máquina a máquina**
 - O serviço prova a própria identidade, não um usuário
- **Workload identity atribui identidade a cada carga**
 - SPIFFE e SPIRE padronizam isso entre plataformas
- **Conta de serviço com escopo mínimo reduz o estrago**

Identidade de workload é a fronteira esquecida

- A maioria das arquiteturas protege bem o login humano
- E deixa serviços trocando segredos estáticos entre si

Credencial de serviço hardcoded é o vetor de movimentação lateral preferido em ataques. Workload identity de curta duração fecha essa porta.

- mTLS via service mesh entrega isso sem código extra



Identidade resolvida, humana e de máquina. Agora vem a pergunta mais difícil do controle de acesso: o que cada identidade realmente pode fazer? E como modelar isso quando a regra depende não só de quem é o usuário, mas do contexto e dos relacionamentos em que ele opera?

Modelos de controle de acesso: RBAC, ABAC e ReBAC